

Internal verification of assessment decisions – BTEC Higher Nationals (RQF)

INTERNAL VERIFICATION – ASSESSMENT DECISIONS (Single Student)					
Programme Title:					
Unit Number and Title:					
Assessor Name:			Internal Verifier Name:		
Assignment title:					
Name of student	Submission Type (First, Resubmission, Retake)	Grade the Assessor has awarded.	Assessment Decision Accurate (Y/N) (Resubmission and retake must be capped at a Pass)	List the learning outcomes and grading criteria where inaccurate decisions have been made	State why the assessment decision is inaccurate. <i>*If an inaccurate decision is recorded the Internal Verifier must recommend actions detailing the issues to be addressed. The Assessor and the Internal Verifier must then confirm that the action has been undertaken before assessment decisions are issued to the student.</i>
INTERNAL VERIFIER CHECKLIST					Y/N
Has the student and the Assessor confirmed the authenticity of the evidence?					

Is there evidence of collusion or plagiarism? The work submitted for assessment has been carried out without assistance other than that which is acceptable according to the rules of the specification. The evidence submitted for this assignment is student's own. The student has clearly referenced any sources and any artificial intelligence (AI) tools used in the work.	
Is the assessor feedback to the student appropriate and constructive to each student? Provide comments below. • Points out strengths and areas for improvement. • Linked to relevant learning outcomes and assessment criteria. • Clear as to why the student did not achieve higher grades. • Identify opportunities for improved performance in future assignments.	
GENERAL COMMENTS	

Any actions required must be reviewed across the whole cohort.		
Action Required	Target Date for Completion	Date Action Completed

I confirm that the assessment decisions are accurate, there is no evidence of assessment malpractice and any action points have been addressed and completed in respect of the whole cohort. I declare the work submitted for assessment has been carried out without assistance other than that which is acceptable according to the rules of the specification. The evidence submitted for this assignment is student's own. The student has clearly referenced any sources and any artificial intelligence (AI) tools used in the work.

Internal Verifier signature		Date	
Assessor signature		Date	

Higher Nationals - Summative Assignment Feedback Form

Student Name/ID	MN. Sihanass / 1030371		
Unit Title	05. Security		
Assignment	Assignment 01	Assessor	Mr. M.I. Mohamed Nismy
Submission Date		Date Received 1st	
Re-submission Date		Date Received 2nd submission	
Assessor Feedback: *Please note that constructive and useful feedback should allow students to understand: a) Strengths of performance b) Limitations of performance c) Any improvements needed in future assessments Feedback should be against the learning outcomes and assessment criteria to help students understand how these inform the process of judging the overall grade. Feedback should give full guidance to the students on how they have met the learning outcomes and assessment criteria.			
<i>I certify that to the best of my knowledge the evidence submitted for this assignment is the student's own. The student has clearly referenced any sources and any artificial intelligence (AI) tools used in the work. I have not solely used AI to grade the student's work.</i>			
Grade:	Assessor Signature:		Date:
Resubmission Feedback: *Please note resubmission feedback is focussed only on the resubmitted work			
Grade:	Assessor Signature:		Date:
Internal Verifier's Comments:			
Signature & Date:			

* Please note that grade decisions are provisional. They are only confirmed once internal and external moderation has taken place and grades decisions have been agreed at the assessment board.

STUDENT ASSESSMENT SUBMISSION AND DECLARATION

When submitting evidence for assessment, each student must sign a declaration confirming that the work is their own.

Student name: MN. Sihanass		Assessor name: Mr. M.I Moahmed Nismy	
Issue date: 04.09.2024	Submission date: 01.12.2024	Submitted on: 29.11.2024	
Programme: Higher National Diploma in Computing			
Unit: 05			
Assignment number and title: Security - 05			

Plagiarism

Plagiarism is a particular form of cheating. Plagiarism must be avoided at all costs and students who break the rules, however innocently, may be penalised. It is your responsibility to ensure that you understand correct referencing practices. As a university level student, you are expected to use appropriate references throughout and keep carefully detailed notes of all your sources of materials for material you have used in your work, including any material downloaded from the Internet. Please consult the relevant unit lecturer or your course tutor if you need any further advice.

Student Declaration

Student declaration I certify that the assignment submission is entirely my own work and I fully understand the consequences of plagiarism. I declare that the work submitted for assessment has been carried out without assistance other than that which is acceptable according to the rules of the specification. I certify I have clearly referenced any sources and any artificial intelligence (AI) tools used in the work. I understand that making a false declaration is a form of malpractice. Student signature: 1030371@bcas.ac Date: 28.11.2024
--

General Guidelines 1. A Cover page or title page - You should always attach a title page to your assignment. Use previous page as your cover sheet and make sure all the details are accurately filled. 2. Attach this brief as the first section of your assignment. 3. All the assignments should be prepared using a word processing software.

4. All the assignments should be printed on A4 sized papers. Use single side printing.
5. Allow 1" for top, bottom, right margins and 1.25" for the left margin of each page.

Word Processing Rules

1. The font size should be 12 poin, and should be in the style of Time New Roman.
2. Use 1.5 line spacing. Left justify all paragraphs.
3. Ensure that all the headings are consistent in terms of the font size and font style.
4. Use footer function in the word processor to insert Your Name, Subject, Assignment No, and Page Number on each page. This is useful if individual sheets become detached for any reason.
5. Use word processing application spell check and grammar check function to help editing your assignment.

Important Points

1. It is strictly prohibited to use text boxes to add texts in the assignments, except for the compulsory information. eg: Figures, tables of comparison etc. Adding text boxes in the body except for the before mentioned compulsory information will result in rejection of your work.
2. Avoid using page borders in your assignment body.
3. Carefully check the hand in date and the instructions given in the assignment. Late submissions will not be accepted.
4. Ensure that you give yourself enough time to complete the assignment by the due date.
5. Excuses of any nature will not be accepted for failure to hand in the work on time.
6. You must take responsibility for managing your own time effectively.
7. If you are unable to hand in your assignment on time and have valid reasons such as illness, you may apply (in writing) for an extension.
8. Failure to achieve at least PASS criteria will result in a REFERRAL grade.
9. Non-submission of work without valid reasons will lead to an automatic RE FERRAL. You will then be asked to complete an alternative assignment.
10. If you use other people's work or ideas in your assignment, reference them properly using HARVARD referencing system to avoid plagiarism. You have to provide both in-text citation and a reference list.
11. If you are proven to be guilty of plagiarism or any academic misconduct, your grade could be reduced to A REFERRAL or at worst you could be expelled from the course.

Unit 05: security

Assignment Brief

Programme Title	Higher National Diploma in Computing
Student Name/ID Number	MN. Sihanass / 1030371
Unit Number and Title	Unit 5: Security
Academic Year	2024
Unit Tutor	Mr. Mohamed Nismy
Assignment Title	Security Solution development for ABC Organization
Issue Date	04.09.2024
Submission Date	01.12.2024
Submission Format	
The submission should be in the form of an individual report written in a concise, formal business style using single spacing and font size 12. You are required to make use of headings, paragraphs and subsections as appropriate, and all work must be supported with research and referenced using Harvard referencing system. Please also provide an end list of references using the Harvard referencing system. The recommended word count is 5,000–5,500 words for the report excluding annexures, although you will not be penalised for exceeding the total word limit.	
Unit Learning Outcomes	
L01 Assess risks to IT security L02 Describe IT security solutions L03 Review mechanisms to control organizational IT security L04 Manage organizational security	
Transferable skills and competencies developed	
Vocational scenario	
ABC organization is a well reputed organization located in Sri-Lanka; this is a company which sells software solutions for consumers. The company up to now outsourced	

people for security related issues, but recently due to their growth and convenience they have decided to establish an IT security team.

Assume that you've recruited for the role of IT security specialist, in ABC company.

Your job role is to manage risks, maintain security standards and maintain network security. As your first task you were asked to conduct following tasks mentioned.

Currently the organization using password and username to log into the organizational devices as well as for the system, and they have a fingerprint machine to take the attendance of employees, the organization does have a firewall but the hardening is not enough. Also, organization do have a policy for password management and information security but needed to be updated.

Assume that, you've assigned to conduct an audit of the company and during this audit you've come to identified following security related issues,

- Some employees are writing their credentials for the PC/system in a stick note and paste it on the monitor.
- They are using the windows early version which is not UpToDate.
- There is no BitLocker or admin protection in company.
- The firewall is not hardened enough.

By taking these issues to consideration, complete below mentioned tasks.

Assignment activity and guidance

TASK 1

1. Discuss the types of security risks can occur to the ABC organization considering the given issues as well. (You can add possible risks towards the ABC company here)
2. Identify the security procedure ABC have and assess common organizational security procedures.
3. By considering the safety of the information and possibility of occurring a network attack the ABC organization you have decided to implement a network monitoring system for the organization, to convince the management to purchase one you have to analyze the benefits of implementing a network monitoring system.

TASK 2

1. Considering the above scenario and other relevant resources, discuss the potential impact to IT security of ABC organization occurred from incorrect configuration of firewall policies and third- party VPNs.

2. You have appointed to propose a method assess and treat IT security risks in the ABC organization, conduct this considering above mentioned issues as well.
3. Discuss using an example for each, specifically detailing the implementation process on the following detailed below,
 - a. DMZ
 - b. Static IP
 - c. NAT
4. By considering above identified issues and other common security issues, evaluate a range of physical and virtual security measures that can be employed to ensure the integrity of ABC organizations' IT security.

TASK 3

1. You've asked to Review risk assessment procedure conducted on ABC organization in Task 02.
2. Explain data protection processes and regulations which can be applied on ABC organization.
3. Summarize ISO 31000- standard with its application in IT security.
4. Analyze possible impacts to security of ABC organization which resulting from the IT security audit conduct.
5. By using above scenario issues as examples as well as other common issues exist, explain the need of IT security to be aligned with IT security policy, also mention the possible impact of misalignments of IT security policy and the security.

TASK 4

1. You've appointed to implement a suitable IT security policy for the ABC organization with a disaster recovery plan.
2. Justify the reasons to select the elements of the above generated disaster recovery plan.
3. Discuss the roles of stakeholders in the ABC organization in implementing security audits.

4. Evaluate the suitability of the tools used in the ABC organizational IT security policy to meet business needs.

Recommended Resources

Please note that the resources listed are examples for you to use as a starting point in your research – the list is not definitive.

Learning Outcomes and Assessment Criteria

Pass	Merit	Distinction
LO1 Assess risks to IT security		
P1 Discuss types of security risks to organisations.	M1 Analyse the benefits of implementing network monitoring systems with supporting reasons.	
P2 Assess organisational security procedures		
LO2 Describe IT security solutions		
P3 Discuss the potential impact to IT security of incorrect configuration of firewall policies and third-party VPNs.	M2 Propose a method to assess and treat IT security risks.	
P4 Discuss, using an example for each, how implementing a DMZ, static IP and NAT in a network can improve network security.		

LO3 Review mechanisms to control organisational IT security		
P5 Review risk assessment procedures in an organisation. P6 Explain data protection processes and regulations as applicable to an organisation.	M3 Summarise an appropriate risk management approach or ISO standard and its application in IT security. M4 Analyse possible impacts to organisational security resulting from an IT security audit	
LO4 Manage organisational security		
P7 Design a suitable security policy for an organisation, including the main components of an organisational disaster recovery plan. P8 Discuss the roles of stakeholders in the organisation in implementing security audits	M5 Justify the security plan developed giving reasons for the elements selected.	

Acknowledgement

I would like to express my sincere gratitude to MI Mohamed Nismy for his guidance and support throughout the course of this assignment. His valuable insights and feedback helped me enhance the quality of my work. I also appreciate the resources and materials provided by the faculty, which significantly contributed to my understanding of IT security practices. Finally, I would like to thank my peers for their constructive discussions, which have enriched my learning experience.

Abstract

This assignment examines the security landscape of the ABC organization, focusing on identifying potential security risks, evaluating current security procedures, and proposing solutions to mitigate these risks. With the rapid growth of the company and the increasing complexity of security challenges, this paper investigates various security practices, including password management, firewall policies, and network security. Additionally, the assignment explores essential IT security regulations such as GDPR, CCPA, and ISO 31000, and proposes a disaster recovery plan tailored to the organization's needs. By identifying the roles of various stakeholders in security audits and suggesting appropriate methodologies, this report aims to provide a comprehensive overview for strengthening ABC's overall security posture.

Table of Contents

Introduction.....	1
1.1 types of security risks can occur to the ABC organization considering the given issues as well	2
1.1.1 Credential Exposure	2
1.1.2 Outdated Operating Systems	3
1.1.3 Lack of Encryption and Admin Protection	3
1.1.4 Insufficient Firewall Hardening	4
1.1.5 Social Engineering Attacks	4
1.1.6 Data Breaches and Legal Liabilities.....	4
1.2 Identify the security procedure ABC organization has and assess common organizational security procedures.....	5
1.2.1 Current Security Procedures at ABC Organization	5
1.2.2 Common Organizational Security Procedures	6
1.2.3 Assessing ABC's Security Procedures	7
1.3 Analyzing the Benefits of Implementing a Network Monitoring System at ABC Organization .	8
1.3.1 Real-Time Network Visibility	8
1.3.2 Early Threat Detection and Response	8
1.3.3 Ensuring Data Integrity and Safety.....	9
1.3.4 Improved Network Performance and Resource Utilization	9
1.3.5 Proactive Management and Automated Alerts	9
1.3.6 Compliance with Security Standards	10
1.3.7 Cost Efficiency.....	10
1.3.8 Comparison of Network Monitoring Systems available in market	11
2.1 Impact of Incorrect Firewall Configuration and Third-Party VPNs on IT Security at ABC Organization	12
2.1.1 Increased Exposure to Unauthorized Access.....	12
2.1.2 Vulnerability to Malware and Ransomware Attacks	13
2.1.3 Reduced Control Over Network Traffic	13
2.1.4 Risk from Unsecured Third-Party VPNs.....	13
2.1.5 Network Performance and Stability Issues.....	14
2.1.6 Lack of Audit Trails for Security Incidents.....	14
2.2 Proposed Method to Assess and Treat IT Security Risks in ABC Organization	15
2.2.1 Risk Assessment method	15
2.2.2 Risk Treatment method	16
2.3 Implementation and Impact of DMZ, Static IP, and NAT.....	17
2.3.1 DMZ (Demilitarized Zone)	17
2.3.2 Static IP.....	18
2.3.3 NAT (Network Address Translation)	19
3.1 Reviewing the proposed Risk Assessment Procedure	20
3.1.1 Risk Assessment Matrix for ABC Organization	20

3.1.2 Action Plan for Each Asset	22
3.1.3 Plan for High-Priority Risks	23
3.2 Explain Data Protection Processes and Regulations for ABC Organization	24
3.2.1 Data Protection Processes for ABC Organization	24
3.2.2 Applicable Regulations and Policies	25
3.2.3 Policy Recommendations for ABC Organization	29
3.2.4 Benefits of Adopting Regulations and Policies	29
3.3 ISO 31000 Standard and Its Application in IT Security	30
3.3.1 Overview of ISO 31000	30
3.3.2 Application of ISO 31000 in IT Security	31
3.3.3 Benefits of ISO 31000 in IT Security	32
3.4 Analysis of Possible Impacts to Security from IT Security Audit at ABC Organization	33
3.4.1 Positive Impacts	33
3.4.2 Potential Negative Impacts	34
3.4.3 Recommendations for Mitigating Negative Impacts	35
4.1 Implementation of an IT Security Policy with a Disaster Recovery Plan for ABC Organization	36
4.1.1 IT Security Policy for ABC Organization	36
4.1.2 Disaster Recovery plan and its main components	38
4.2 Justification of the Disaster Recovery Plan for ABC Organization	43
4.2.1 Risk Assessment and Business Impact Analysis (BIA)	43
4.2.2 Recovery Objectives (RTO and RPO)	43
4.2.3 Backup Strategies	44
4.2.4 Disaster Recovery Team	44
4.2.5 Disaster Recovery Sites	44
4.2.6 Communication Plan	45
4.2.7 Testing and Maintenance	45
4.3 Roles of Stakeholders in Implementing Security Audits for Organization	46
4.3.1 What is a Security Audit in Organizations?	46
4.3.2 Roles of Stakeholders in Implementing a Security Audit in the Organization	47
4.3.3 Responsibilities of Stakeholders in Implementing a Security Audit in the Organization	48
Conclusion	49
References	50

List of tables

Table 1: comparison of network monitoring system that available in the market	11
Table 2: Risk assessment matrix for ABC organization	21
Table 3: action plan for identified threats	22
Table 4: security policy for the organization ((NIST), 2020).....	37
Table 6: integrated disaster recovery plan for the organization.....	42

Table of figures

Figure 1: credential exposure (News, 2022)	2
Figure 2: outdated operating system (Lakin, 2024)	3
Figure 3: understanding data encryption (WIKIPEDIA, 2024)	3
Figure 4: firewall threats (paloalto, 2024)	4
Figure 5: how to configure firewall correctly (paloalto, 2024)	12
Figure 6: DMZ architecture	17
Figure 7: what is GDPR? (investopedia, 2024)	25
Figure 8: what is CCPA? (Gracy, 2023)	26
Figure 9: how does ISMS works? (yasar, 2022)	27
Figure 10: functions of NIST (Miller, 2022)	28
Figure 11: ISO 31000 risk management process (T, 2022)	30
Figure 12: seven components of a disaster recovery plan (Kadlec, 2024)	38

Introduction

ABC organization, a leading software solution provider based in Sri Lanka, is undergoing significant expansion, requiring a more structured and robust approach to managing its IT security. The company has recognized the need to move away from outsourcing security tasks and has recruited an internal IT security specialist to address the growing security concerns. The assignment delves into the current state of security within the organization, identifies existing vulnerabilities, and recommends various strategies to address these issues. By focusing on risk assessment procedures, security audits, disaster recovery, and security policy design, this paper aims to provide a clear roadmap for enhancing ABC's IT security infrastructure.

1.1 types of security risks can occur to the ABC organization considering the given issues as well

ABC Organization, which provides software solutions, faces several security risks due to both identified vulnerabilities and general organizational practices. The following discussion outlines the key risks the company may face:

1.1.1 Credential Exposure



Figure 1: credential exposure (News, 2022)

One of the major risks involves employees writing down their credentials on sticky notes and leaving them on their monitors. This practice can lead to unauthorized access, as anyone with physical access to the office can easily view these credentials. This weakens the first layer of defense authentication and increases the risk of data breaches, system compromise, and identity theft. (Romero, 2022)

1.1.2 Outdated Operating Systems

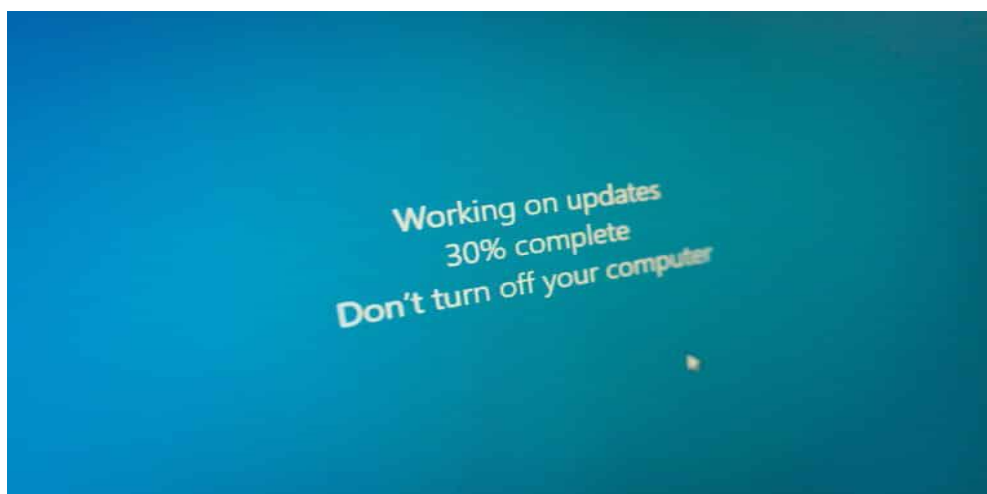


Figure 2: outdated operating system (Lakin, 2024)

The organization's use of outdated Windows versions, which are no longer supported with security patches, makes the systems vulnerable to a wide range of threats, including malware, ransomware, and zero-day attacks. Without regular updates, these systems may have unpatched vulnerabilities that can be easily exploited by attackers. This risk could lead to system failure, data loss, and exploitation of software vulnerabilities by malicious actors. (Pagnotta, 2024)

1.1.3 Lack of Encryption and Admin Protection

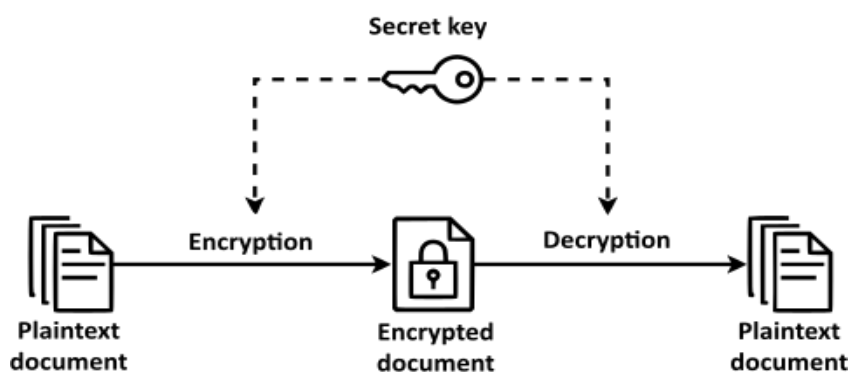


Figure 3: understanding data encryption (WIKIPEDIA, 2024)

The absence of BitLocker or any other encryption mechanisms means that data stored on devices is not adequately protected, particularly if devices are lost or stolen. This presents a significant risk of data theft and compromise. Additionally, without administrative protection, there is a heightened risk of insider threats, accidental configuration changes, and unauthorized access to sensitive areas of the system. (Daalen, 2023)

1.1.4 Insufficient Firewall Hardening

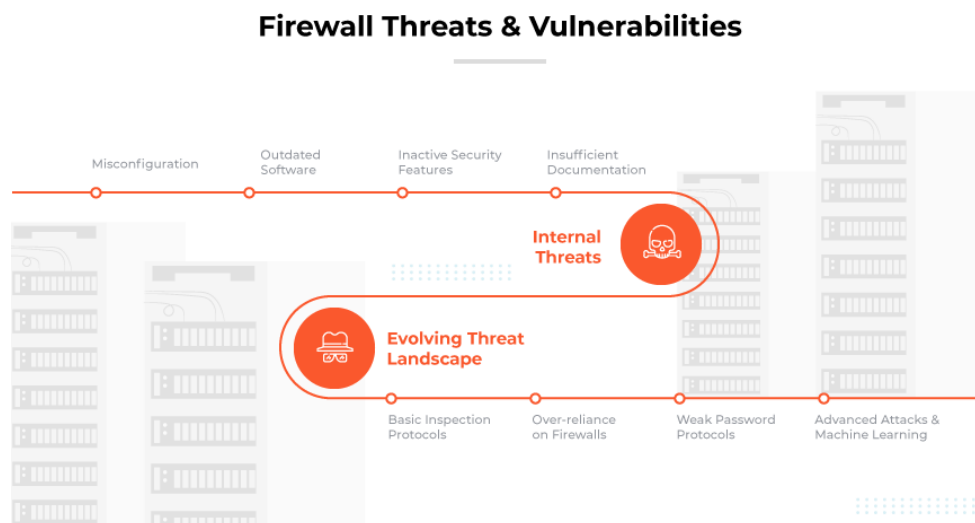


Figure 4: firewall threats (paloalto, 2024)

Although the company has implemented a firewall, the insufficient hardening exposes the network to external threats such as Distributed Denial of Service (DDoS) attacks, brute force attacks, and unauthorized access. A poorly configured firewall may allow unintended traffic into the network, thereby increasing the risk of exploitation by cybercriminals (Easttom, 2020).

1.1.5 Social Engineering Attacks

Employees' poor credential management practices (e.g., using sticky notes for passwords) also create the potential for social engineering attacks such as phishing, where attackers could manipulate employees into divulging sensitive information. ABC Organization is at risk of both targeted attacks and opportunistic breaches if this behavior continues unchecked (Mitnick & Simon, 2011).

1.1.6 Data Breaches and Legal Liabilities

Should any of these vulnerabilities be exploited, ABC Organization is likely to face significant consequences in the form of data breaches. This can lead to reputational damage, legal liabilities, and non-compliance with data protection regulations such as the General Data Protection Regulation (GDPR), which requires organizations to implement appropriate technical and organizational measures to ensure data security (European Union, 2016).

1.2 Identify the security procedure ABC organization has and assess common organizational security procedures

ABC Organization currently implements several security procedures, although they are inadequate in many respects. By comparing these with common best practices, we can identify gaps and opportunities for improvement.

1.2.1 Current Security Procedures at ABC Organization

- **Password and Username Authentication:** ABC uses basic username and password credentials to secure access to their systems. While this is a common method of authentication, its effectiveness is undermined by poor practices such as employees writing their credentials on sticky notes.
- **Fingerprint Attendance System:** The company has implemented a fingerprint-based attendance system for employee check-ins, which introduces biometric security to some extent.
- **Firewall Implementation:** ABC has a firewall in place, though it is insufficiently hardened, leaving the network vulnerable to attacks.
- **Password and Information Security Policy:** ABC has a policy in place for password management and information security, but it requires updating to reflect more robust security standards and practices.

1.2.2 Common Organizational Security Procedures

Comparing ABC's practices with industry standards reveals several areas for improvement. Common organizational security procedures include:

- **Multi-Factor Authentication (MFA):** In addition to usernames and passwords, many organizations employ multi-factor authentication (MFA) to enhance security. MFA requires users to verify their identity through multiple means, such as a password and a one-time code sent to a mobile device. This makes it significantly harder for attackers to gain unauthorized access, even if they obtain the user's credentials (Tance Suleski, 2023).
- **Data Encryption:** Many organizations utilize data encryption, such as BitLocker, to protect sensitive data stored on devices and networks. Encryption ensures that, even if data is intercepted or stolen, it cannot be easily read or exploited. The absence of encryption at ABC increases the risk of data breaches and theft (Liu, 2022).
- **Regular System Updates and Patches:** To safeguard against emerging threats, organizations regularly update their operating systems and software, ensuring that they are protected against known vulnerabilities. By using outdated Windows versions, ABC is exposing itself to risks associated with unpatched software vulnerabilities (Farrier, 2024).
- **Firewall Hardening:** Firewalls play a critical role in controlling network traffic and protecting against unauthorized access. However, proper firewall configuration and hardening are essential for maximizing protection. This includes setting rules for blocking untrusted networks, configuring logging for traffic monitoring, and updating firewall firmware regularly. ABC's current firewall setup is insufficiently hardened, making it vulnerable to attacks (Osaji, 2020).

- **Security Awareness Training:** Many organizations implement regular security awareness training for employees. These programs educate staff on best practices for credential management, recognizing phishing attacks, and maintaining overall cybersecurity hygiene. At ABC, the fact that employees are writing credentials on sticky notes suggests a lack of awareness about the importance of security practices (Terra, 2024).
- **Access Control:** Strict access control measures are important in minimizing insider threats. Many organizations implement role-based access control (RBAC), where employees are granted access only to the information and systems necessary for their job functions. At ABC, there is no mention of advanced access control mechanisms, which could increase the risk of unauthorized access (Burge, 2023).

1.2.3 Assessing ABC's Security Procedures

While ABC Organization has implemented some basic security measures, such as authentication and firewall usage, these procedures fall short of common industry practices. ABC's reliance on outdated methods (password-only authentication, unpatched operating systems, and weak firewall configurations) increases the organization's vulnerability to both internal and external threats. Additionally, the absence of encryption, insufficient user education, and outdated security policies further compound the risk.

By adopting more robust security measures, such as multi-factor authentication, encryption, system updates, and security training, ABC can greatly enhance its overall security posture.

1.3 Analyzing the Benefits of Implementing a Network Monitoring System at ABC Organization

With the growing risk of network attacks and the need to protect sensitive information, ABC Organization must adopt advanced security measures. One of the most effective ways to enhance the security of a network is by implementing a network monitoring system. This system provides real-time insights into network performance and detects potential threats, helping IT teams respond proactively to incidents.

1.3.1 Real-Time Network Visibility

A network monitoring system provides continuous monitoring of all network activities, offering real-time visibility into network traffic. It helps IT staff detect unusual behaviour, such as unexpected data transfers or unauthorized access attempts, which could indicate a security breach. This feature is crucial in preventing network attacks before they escalate into more significant issues (Kernitskyi, 2024).

- **Benefit:** By constantly tracking network traffic, ABC Organization can detect anomalies early and respond swiftly to mitigate threats, reducing the likelihood of successful attacks.

1.3.2 Early Threat Detection and Response

Network monitoring systems come equipped with **intrusion detection** and **intrusion prevention** capabilities. These tools analyze network traffic patterns and compare them against known attack signatures, allowing the system to flag suspicious activities in real time. With such a system in place, ABC can reduce the risk of attacks such as Distributed Denial of Service (DDoS), man-in-the-middle attacks, and data breaches (Liu, 2024).

- **Benefit:** Implementing network monitoring can enhance ABC's ability to detect cyber threats and prevent malicious activities, reducing downtime and safeguarding the organization's data and infrastructure.

1.3.3 Ensuring Data Integrity and Safety

One of the key advantages of network monitoring is that it helps maintain the **integrity and confidentiality of sensitive information**. ABC Organization handles valuable data related to its software solutions and customers, making it a target for data breaches. A network monitoring system can track the movement of sensitive information across the network and alert administrators to unauthorized access or data exfiltration attempts (Harshit Kumar J. Ghelani, 2023).

- **Benefit:** This system will help ABC ensure that sensitive information, such as customer data and proprietary software, remains secure and uncompromised.

1.3.4 Improved Network Performance and Resource Utilization

A network monitoring system not only improves security but also helps with **network performance management**. It provides insights into bandwidth usage, latency, and overall network health. By identifying network bottlenecks or hardware failures, the system allows IT staff to optimize resources and maintain high network performance.

- **Benefit:** For ABC, this means minimizing network outages and ensuring smooth access to critical systems, enhancing overall productivity (Lamberti, 2024).

1.3.5 Proactive Management and Automated Alerts

Network monitoring systems can be configured to send **automated alerts** when predefined thresholds are met, such as excessive bandwidth usage or unusual login attempts. This allows IT teams to take immediate action, even before users notice a problem. The system can also offer automated responses to certain events, such as blocking malicious IP addresses.

- **Benefit:** ABC can benefit from reduced manual oversight, allowing the IT team to focus on strategic tasks while the monitoring system handles routine detection and reporting (Claudia.Landivar, 2023).

1.3.6 Compliance with Security Standards

Implementing a network monitoring system helps organizations comply with various **regulatory requirements** for data protection, such as the General Data Protection Regulation (GDPR). These systems generate detailed logs of network activities, which are essential for auditing purposes and proving compliance in case of an investigation.

- **Benefit:** By adopting a network monitoring system, ABC will not only protect its data but also ensure compliance with legal and industry regulations, avoiding fines and legal consequences (Tunggal, 2024).

1.3.7 Cost Efficiency

While the initial investment in a network monitoring system may seem high, it leads to **long-term cost savings**. By preventing cyberattacks and minimizing downtime, ABC can avoid the significant financial losses associated with breaches, including recovery costs, reputational damage, and potential fines.

- **Benefit:** Network monitoring offers a high return on investment by preventing costly incidents and ensuring network reliability (V.B. Godagama, 2023).

1.3.8 Comparison of Network Monitoring Systems available in market

Monitoring System	Price (Approx.)	Key Features	Purpose	Compatibility
SolarWinds NPM	577284 LKR (one-time)	Advanced alerts, customizable dashboards, NetPath	Comprehensive network performance monitoring	Windows, Cloud-based
Paessler PRTG	462985 LKR for 500 sensors	Bandwidth usage tracking, app monitoring, maps	Unified monitoring for all IT infrastructure	Windows, Mobile Apps (iOS, Android)
Nagios XI	570000 LKR (one-time)	Log management, real-time monitoring, alerts	Monitoring server performance and application	Windows, Linux
ManageEngine OpManager	70894 LKR/year (standard)	Network visualization, fault management, reports	Monitoring devices like switches, servers	Windows, Linux
Zabbix	Free (Open Source)	SNMP monitoring, distributed monitoring	Enterprise-level monitoring for IT components	Windows, Linux, Mac, Cloud
Datadog	4340 LKR/host/month	Cloud integration, log analytics, infrastructure	Monitoring cloud-based and hybrid environments	Windows, Mac, Cloud-based, Mobile Apps

Table 1: comparison of network monitoring system that available in the market

2.1 Impact of Incorrect Firewall Configuration and Third-Party VPNs on IT Security at ABC Organization

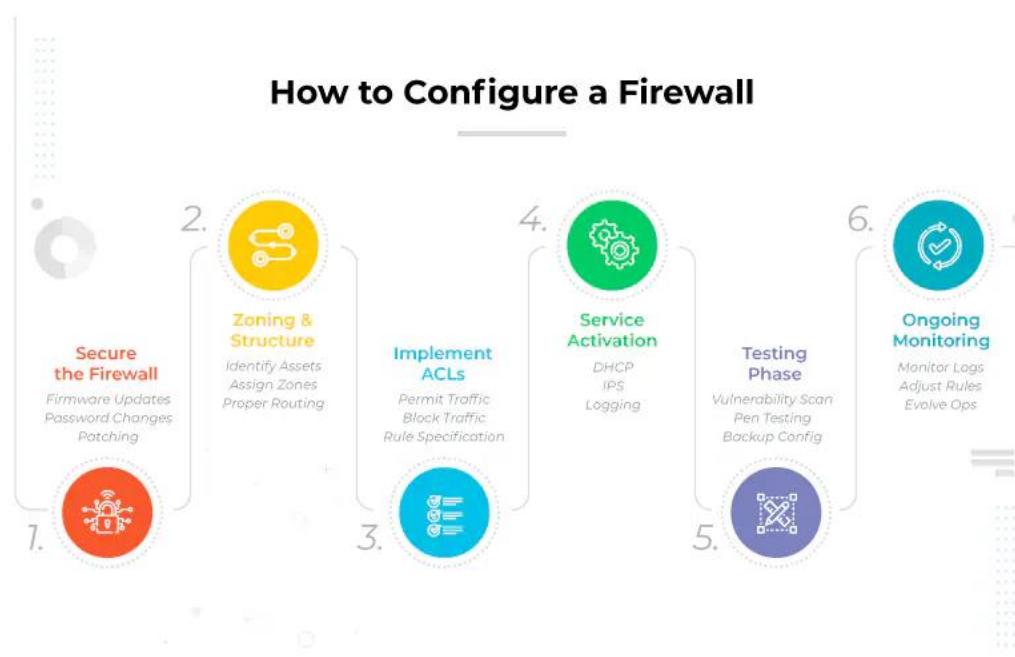


Figure 5: how to configure firewall correctly (paloalto, 2024)

Firewall policies and Virtual Private Networks (VPNs) are foundational to securing a network. In the case of ABC Organization, errors in firewall configuration or third-party VPN management can expose the organization to several IT security risks. Below are the potential impacts:

2.1.1 Increased Exposure to Unauthorized Access

Incorrectly configured firewall policies may unintentionally allow unrestricted access to sensitive areas of the network, permitting unauthorized users to enter. For example, open ports or inadequate filtering can expose critical internal systems to external threats, increasing the risk of data breaches or malicious access (Easttom, 2020).

- **Impact:** ABC's customer data, proprietary software, and employee information could be compromised, leading to privacy violations and potential financial and reputational damage.

2.1.2 Vulnerability to Malware and Ransomware Attacks

A misconfigured firewall might fail to block malicious traffic, allowing malware, ransomware, or spyware to penetrate the organization's network. Without the right filtering, ABC could become susceptible to these threats, resulting in data encryption, data loss, or system hijacking (Chapple, 2019).

- **Impact:** The organization may face prolonged downtime, data recovery costs, and damage to its reputation if it cannot protect against malware or ransomware.

2.1.3 Reduced Control Over Network Traffic

Firewalls are essential for segmenting network traffic and managing what enters and exits the network. Misconfigured firewalls may compromise this segmentation, allowing sensitive internal traffic to mix with less secure traffic or permitting unrestricted data flow to the internet.

- **Impact:** This makes it easier for attackers to intercept data, potentially leading to sensitive information leaks or loss of control over network traffic patterns (Goel, 2014).

2.1.4 Risk from Unsecured Third-Party VPNs

Many organizations, including ABC, may rely on third-party VPNs to provide secure remote access. However, unsecured or improperly managed third-party VPNs can expose the network to various risks, such as VPN hijacking or weak encryption standards, which attackers can exploit (Anderson, 2016). Without strong encryption, unauthorized entities could intercept data transmitted over the VPN, leading to exposure of sensitive information.

- **Impact:** This can result in data breaches, loss of privacy, and unauthorized access to internal systems, posing severe risks to ABC's security framework.

2.1.5 Network Performance and Stability Issues

Firewalls often handle massive amounts of traffic. Incorrect configurations can degrade network performance, leading to slowdowns or unavailability of services. This can affect ABC's ability to provide reliable service to its clients, impacting productivity and potentially causing client dissatisfaction.

- **Impact:** Reduced network performance can lead to productivity losses, which in turn can affect ABC's service reliability and overall customer satisfaction (Mitnick, 2011).

2.1.6 Lack of Audit Trails for Security Incidents

Proper firewall configuration enables the logging and tracking of network events, which are crucial for auditing and investigating security incidents. If firewall policies are misconfigured, ABC could lose vital security event logs, making it difficult to trace the source of an incident or attack.

- **Impact:** Without these logs, ABC may face challenges in incident response and compliance, as well as issues in understanding the scope of any potential security breaches (Union, 2016).

2.2 Proposed Method to Assess and Treat IT Security Risks in ABC Organization

A structured approach to assessing and treating IT security risks ensures that ABC Organization's unique vulnerabilities are effectively identified, evaluated, and mitigated. A recommended method involves **Risk Assessment** and **Risk Treatment** phases, supported by ISO 27005's framework for information security risk management.

2.2.1 Risk Assessment method

2.2.1.1 Identify Risks

- **Objective:** Recognize specific vulnerabilities within the organization, such as inadequate firewall policies, outdated software, and insecure password practices.
- **Actions:** Conduct interviews with employees, analyze system logs, and review security protocols (Crockford, 2022). Document all identified risks, especially those related to credentials written on sticky notes, obsolete operating systems, lack of BitLocker, and weak firewall policies.

2.2.1.2 Risk Analysis

- **Objective:** Determine the likelihood and impact of each identified risk.
- **Actions:** Use a qualitative or quantitative scoring method to evaluate the impact and probability of each risk. Risks such as unauthorized access due to weak credentials can be rated high-impact and high-likelihood, as they could directly expose ABC's sensitive information to threats (Stoneburner, et al., 2012).

2.2.1.3 Risk Evaluation

- **Objective:** Rank risks based on their analysis scores to prioritize treatment.
- **Actions:** Develop a risk matrix to categorize risks as high, medium, or low priority. For ABC, risks related to outdated operating systems and poor firewall hardening should be ranked high priority due to the potential for significant security breaches.

2.2.2 Risk Treatment method

2.2.2.1 Risk Mitigation (Reducing the Likelihood and Impact)

- **Objective:** Implement strategies that lower the identified risks.
- **Actions:** Strengthen firewall configurations and VPN security to reduce network vulnerabilities. Implement a mandatory two-factor authentication (2FA) policy and reinforce BitLocker protection on all devices to safeguard against data theft (Tariq, 2018). Ensure regular OS updates to close known security gaps.

2.2.2.2 Risk Acceptance

- **Objective:** Acknowledge low-impact, low-likelihood risks that may not need immediate mitigation.
- **Actions:** Accept minor risks that do not significantly affect the organization. For instance, lower-impact issues like individual employee non-compliance with minor policies can be accepted if the overall compliance level is satisfactory.

2.2.2.3 Risk Transfer

- **Objective:** Transfer high-cost risks to external parties, such as third-party security vendors.
- **Actions:** Outsource the most complex network monitoring tasks to a cybersecurity firm specializing in continuous monitoring, which can identify anomalies and raise alerts.

2.2.2.4 Risk Avoidance

- **Objective:** Eliminate risks by changing how certain activities are performed.
- **Actions:** Establish a policy forbidding sticky notes for credential storage. Implement security awareness training to avoid risky practices among employees, thus reducing human error (Gordon, 2021).

After implementing risk treatment actions, ongoing monitoring is crucial to detect emerging threats and measure the effectiveness of current controls. This phase ensures that ABC Organization's security posture remains robust and that the risk treatment strategies are continuously aligned with changing security requirements.

2.3 Implementation and Impact of DMZ, Static IP, and NAT

2.3.1 DMZ (Demilitarized Zone)

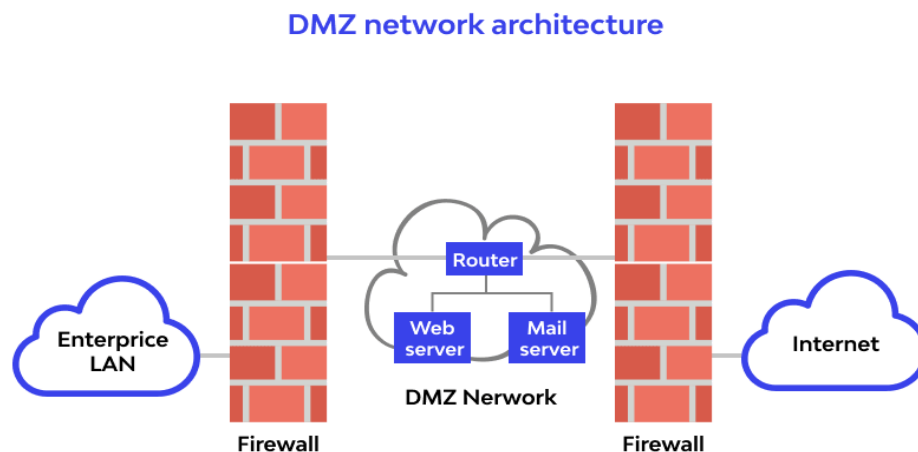


Figure 6: DMZ architecture

What if DMZ is not implemented?

Without a DMZ, external users can directly access internal network resources, increasing the risk of exposing sensitive data or systems to cyberattacks like malware infections and unauthorized access. The internal network is more vulnerable to lateral movement attacks if one system is compromised. (Emmett Dulaney, 2021)

What if DMZ is implemented?

A DMZ provides an additional layer of security by isolating externally accessible services from the internal network. External users interact only with resources in the DMZ (e.g., web servers), while the internal network remains protected.

Example of Implementation:

1. **Create a DMZ Network:** Use a separate VLAN or subnet to segment public-facing services like web or email servers.
2. **Firewall Configuration:**
 - Deploy two firewalls, one between the internet and DMZ, and another between the DMZ and the internal network.
 - Set rules to allow public traffic to reach only specific services in the DMZ.

3. **Place Systems in the DMZ:** Move services like a web server to the DMZ. For instance, hosting a company website in the DMZ ensures external users can access it without risking internal systems.

Impact:

With a DMZ, ABC Organization reduces its attack surface by limiting exposure of the internal network while maintaining availability of public-facing services (Tittel, 2020).

2.3.2 Static IP

What if Static IP is not implemented?

Without Static IP, services relying on consistent IP addresses (e.g., VPN servers, DNS) may fail due to dynamically assigned IPs. This inconsistency disrupts connectivity and affects service reliability.

What if Static IP is implemented?

Static IP ensures services have consistent addresses, improving reliability and accessibility for critical resources like VPNs or mail servers. (McMillan, 2019)

Example of Implementation:

1. **Assign Static IPs:**

- Identify devices needing static IPs (e.g., VPN gateway, mail server).
- Configure static IP settings manually via the device's network adapter or router.
- Example: Assign 192.168.1.100 to the VPN gateway.

2. **DNS Configuration:**

- Update DNS records to point to the static IP, ensuring services are reachable by domain names.

3. **Testing:** Ensure consistent service availability by verifying connections to devices using the static IP.

Impact:

Static IP simplifies network management, ensures seamless service delivery, and supports stable remote access for ABC's VPN users and critical resources.

2.3.3 NAT (Network Address Translation)

What if NAT is not implemented?

Without NAT, internal devices use public IPs directly, exposing them to external threats. It becomes difficult to manage limited public IP addresses, leading to inefficient resource allocation.

What if NAT is implemented?

NAT hides internal IP addresses by translating them into a single public IP address when accessing the internet, improving security and conserving public IPs.

Example of Implementation:

1. **Setup NAT on Firewall/Router:**
 - Configure the router/firewall to perform NAT, mapping private IP ranges (e.g., 192.168.x.x) to a single public IP.
 - Example: A router translates internal requests from 192.168.1.10 to a public IP like 203.0.113.5.
2. **Port Forwarding (Optional):** Configure port forwarding to allow access to internal services, such as forwarding 80 for a web server.
3. **Testing:** Verify external communication by accessing the internet or hosted services through the NAT-enabled router.

Impact:

NAT enhances security by hiding internal devices from direct external access, while efficiently using public IP resources for ABC's expanding infrastructure. (Gordon, 2021)

3.1 Reviewing the proposed Risk Assessment Procedure

3.1.1 Risk Assessment Matrix for ABC Organization

Below is the proposed matrix for the identified assets and threats from Task 2.2, with columns for asset, threat, probability, harm, risk level, and control. The chart ensures a clear understanding of high-priority areas, allowing for efficient allocation of resources to mitigate risks:

Asset	Threat	Probability (1-5)	Harm (1-5)	Risk (Probability × Harm)	Control
Employee Credentials	Sticky notes with passwords	4	5	20	Enforce password policies, implement password managers, and train employees.
Operating Systems	Outdated Windows versions	5	5	25	Upgrade to supported versions, enable automatic updates, and apply patches regularly.

Device Storage	Lack of BitLocker/admin protection	4	4	16	Enable BitLocker encryption and enforce admin privileges for system-critical tasks.
Network Infrastructure	Weak firewall configuration	4	5	20	Harden firewall policies, implement IDS/IPS, and conduct regular penetration testing.
Password Management Policy	Weak and outdated password policy	3	4	12	Update password policy to enforce complexity, expiration, and reuse limitations.
VPN Connections	Misconfigured third-party VPNs	3	5	15	Configure secure VPN protocols (IPSec/SSL), audit VPN settings, and train employees on VPN usage.

Table 2: Risk assessment matrix for ABC organization

3.1.2 Action Plan for Each Asset

For each identified asset and threat, the following action plan provides the treatment method (Acceptance, Avoidance, or Mitigation):

Asset	Action Plan	Treatment
Employee Credentials	Educate employees on secure credential handling, eliminate sticky notes, and deploy enterprise-grade password management tools (Smith, 2021).	Mitigation
Operating Systems	Schedule immediate upgrades to supported Windows versions and automate regular patch updates to maintain compliance and reduce vulnerabilities (Taylor, 2020).	Avoidance
Device Storage	Enable BitLocker on all systems to encrypt sensitive data and enforce stricter admin-level access controls (Williams, 2019).	Mitigation
Network Infrastructure	Conduct a firewall audit to reconfigure access rules and implement an Intrusion Detection/Prevention System (IDS/IPS) (Patel, 2022).	Mitigation
Password Policy	Update policies to enforce strong password creation, implement mandatory periodic changes, and prevent reuse of previous passwords (Wilson, 2021).	Mitigation
VPN Connections	Replace outdated VPN configurations with secure protocols like IPSec, enforce MFA (Multi-Factor Authentication), and conduct regular audits (Gupta, 2018).	Mitigation

Table 3: action plan for identified threats

3.1.3 Plan for High-Priority Risks

High-priority risks include outdated operating systems and weak firewall configurations (risk levels of 25 and 20, respectively). Below is the detailed plan:

1. Outdated Operating Systems (Risk Level: 25)

➤ **Action Steps:**

- Prioritize system upgrades to the latest supported versions of Windows.
- Implement an auto-update mechanism for operating systems and critical applications.
- Conduct vulnerability scans post-upgrade to identify potential gaps.

➤ **Expected Outcome:**

Enhanced resilience against malware, ransomware, and system exploitation.

2. Weak Firewall Configuration (Risk Level: 20)

➤ **Action Steps:**

- Conduct a firewall audit to identify open ports and unnecessary services.
- Create access control lists (ACLs) to restrict unauthorized traffic.
- Deploy IDS/IPS systems to monitor and block malicious activity.

➤ **Expected Outcome:**

Reduced exposure to network-based attacks, ensuring robust perimeter defense.

3.2 Explain Data Protection Processes and Regulations for ABC Organization

3.2.1 Data Protection Processes for ABC Organization

To ensure data security and regulatory compliance, ABC Organization should adopt the following data protection processes.

1. Data Classification and Access Control

- Classify data into categories such as public, internal, sensitive, and confidential based on its criticality to operations.
- Implement **Role-Based Access Control (RBAC)** to limit access to sensitive information to authorized personnel only (Standardization, 2018).

2. Secure Authentication Methods

- Replace current username-password systems with multi-factor authentication (MFA) to enhance security.
- Utilize password policies enforcing complexity, expiration, and unique passwords for all accounts ((NIST), 2020).

3. Regular Security Audits and Penetration Testing

- Conduct periodic security assessments to identify and mitigate vulnerabilities in systems, applications, and networks.

4. Backup and Disaster Recovery Plans

- Regularly back up critical data and store it in offsite locations to ensure availability in the event of data loss or ransomware attacks.

5. Employee Awareness and Training

- Provide training on recognizing phishing scams, protecting credentials, and following organizational data security policies.

3.2.2 Applicable Regulations and Policies

1. General Data Protection Regulation (GDPR)

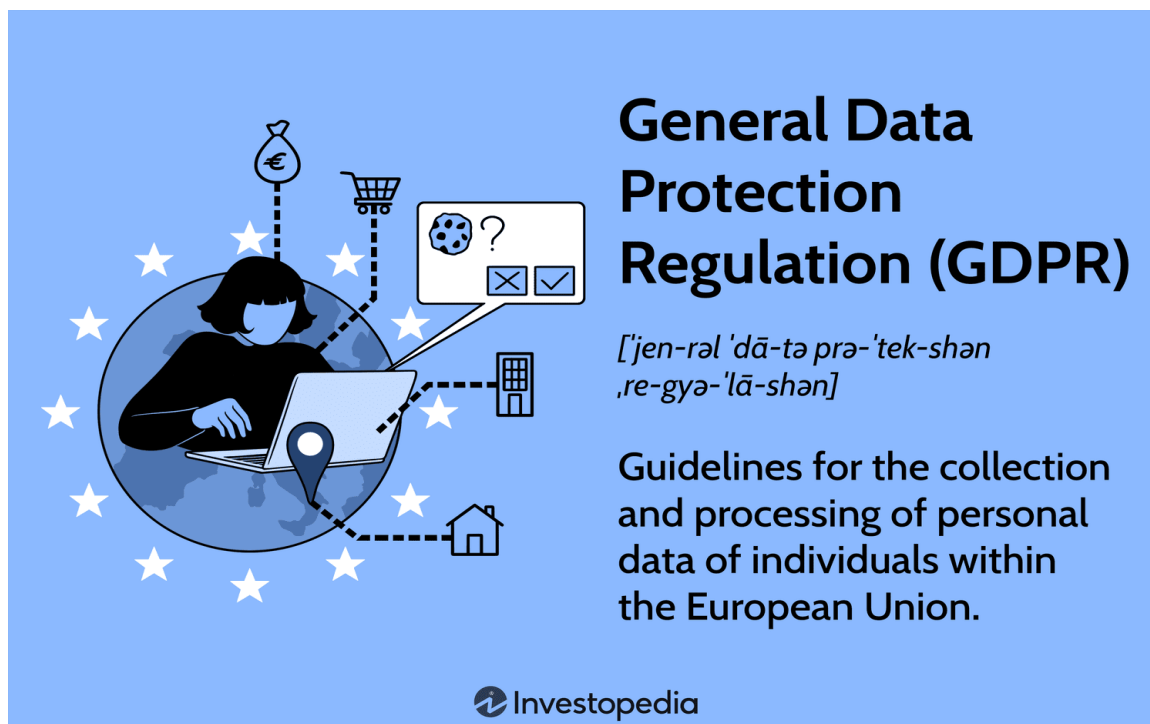


Figure 7: what is GDPR? (investopedia, 2024)

The GDPR is one of the most stringent and globally recognized data protection regulations. It applies to any organization handling the personal data of EU residents, regardless of where the organization is located. ABC Organization must comply if it processes EU citizens' data, ensuring that:

- **Data minimization** restricts the collection of personal data to only what is essential for business operations.
- **Consent management** is mandatory, meaning users must explicitly agree to their data being used for specific purposes.
- **Breach notification** within 72 hours ensures quick responses to protect data subjects and mitigate harm (Commission, 2018).

Application to ABC Organization:

ABC should implement GDPR-compliant systems, such as secure databases for storing user data and encryption to prevent unauthorized access. Training staff on GDPR practices ensures accountability, and breach protocols must be established to address potential incidents promptly.

2. California Consumer Privacy Act (CCPA)

“The California Consumer Privacy Act of 2018 (CCPA) gives consumers more control over the personal information that businesses collect about them, and the CCPA regulations guide how to implement the law.”

State of California
Department of Justice



Figure 8: what is CCPA? (Gracy, 2023)

The CCPA is focused on protecting the data of California residents, requiring organizations to provide transparency in their data handling practices. It ensures that consumers can:

- Know what personal information is collected, how it is used, and with whom it is shared.
- Request deletion of their data and opt out of data sales (General, 2020).

Application to ABC Organization:

If ABC operates in California, it must create clear privacy policies detailing how customer data is handled. Implementing features such as a "Do Not Sell My Data" button on websites and providing users access to their personal data aligns with the CCPA. Staff training and periodic audits ensure compliance.

3. ISO/IEC 27001 - Information Security Management Systems (ISMS)



Figure 9: how does ISMS works? (yasar, 2022)

ISO/IEC 27001 offers a globally recognized framework for managing information security risks. By adopting this standard, organizations can establish and maintain an Information Security Management System (ISMS) to protect sensitive data.

- It emphasizes **risk-based controls** tailored to an organization's specific risks.
- Regular **audits** help in identifying vulnerabilities and ensuring continuous improvement (Standardization, 2018).

Application to ABC Organization:

ABC can benefit by adopting ISO/IEC 27001 to develop a robust security system, covering areas like access control, incident response, and data backup. Certifying the organization in ISO/IEC 27001 increases trust among clients and stakeholders, demonstrating a commitment to data protection.

4. NIST Cybersecurity Framework

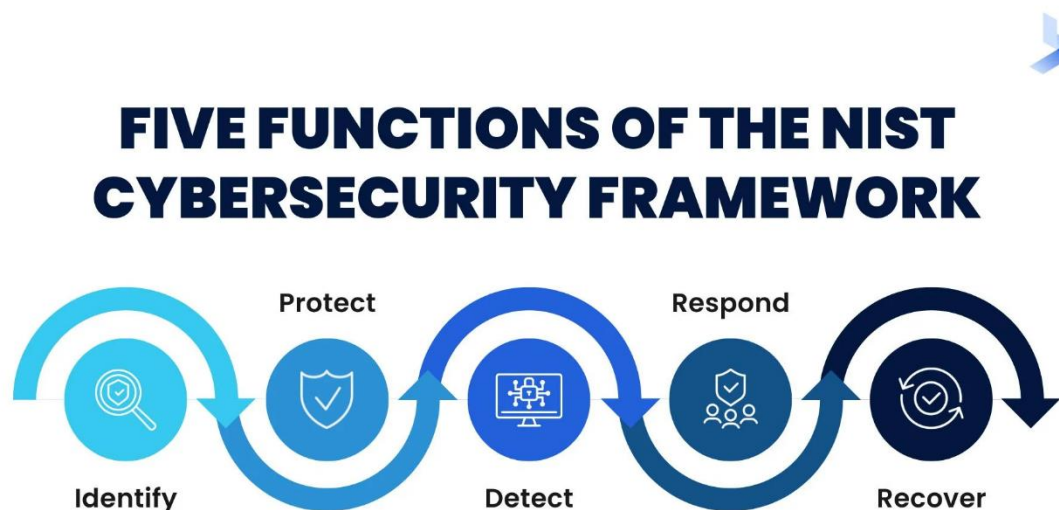


Figure 10: functions of NIST (Miller, 2022)

The NIST Framework provides a risk-based approach for managing cybersecurity. Its five core functions—**Identify, Protect, Detect, Respond, and Recover**—help organizations effectively manage and mitigate risks.

- **Identify:** Recognize assets, risks, and vulnerabilities.
- **Protect:** Implement safeguards to ensure data security.
- **Detect:** Establish mechanisms to identify potential threats.
- **Respond and Recover:** Develop plans to contain and resolve incidents, ensuring business continuity ((NIST), 2020).

Application to ABC Organization:

Adopting NIST helps ABC systematically address cybersecurity threats. For example, using NIST's framework, ABC can create a comprehensive risk management plan, including firewalls, intrusion detection systems (IDS), and response strategies for cyberattacks.

3.2.3 Policy Recommendations for ABC Organization

Based on the identified issues (weak password practices, outdated systems, and lack of proper encryption):

- **Password Management Policy:** Implement a policy mandating strong, unique passwords, regular changes, and avoiding credential sharing. This aligns with both **GDPR** and **NIST standards**.
- **Firewall Policy:** Harden firewall configurations and monitor traffic logs to prevent unauthorized access.
- **Data Retention Policy:** Define guidelines for storing, archiving, and deleting data to ensure compliance with regulations like GDPR and ISO/IEC 27001.
- **Third-Party Risk Management Policy:** Vet vendors to ensure they meet ABC's data protection standards.

3.2.4 Benefits of Adopting Regulations and Policies

- **Reduced Security Risks:** Enhances protection against cyberattacks and unauthorized access.
- **Regulatory Compliance:** Avoids fines and legal actions for non-compliance.
- **Improved Reputation:** Demonstrates commitment to safeguarding user data, improving customer trust.

3.3 ISO 31000 Standard and Its Application in IT Security

3.3.1 Overview of ISO 31000

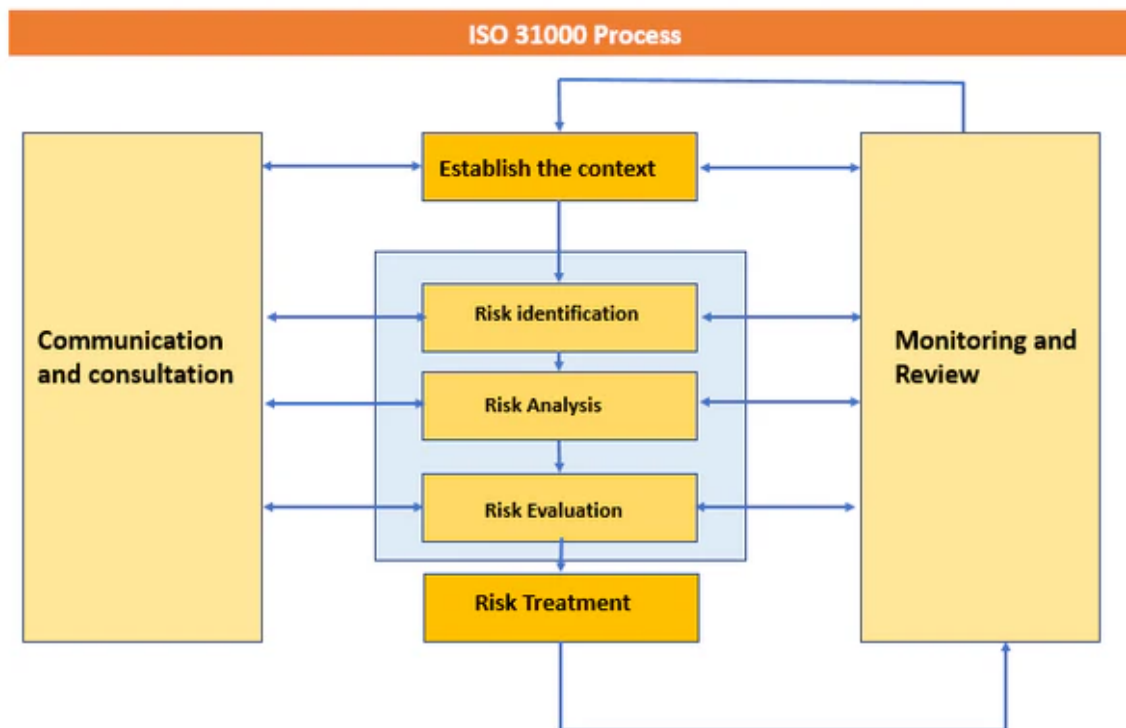


Figure 11: ISO 31000 risk management process (T, 2022)

ISO 31000 is an international standard for risk management, providing guidelines to identify, assess, and mitigate risks effectively. Unlike domain-specific frameworks, ISO 31000 applies broadly to all types of organizations, emphasizing a structured and iterative approach to risk management. Key elements include:

1. **Risk Identification:** Understanding risks that could impact the organization.
2. **Risk Assessment:** Evaluating the likelihood and consequences of identified risks.
3. **Risk Treatment:** Implementing measures to mitigate, transfer, avoid, or accept risks.
4. **Monitoring and Review:** Continuously monitoring risks and updating strategies.

ISO 31000 emphasizes integrating risk management into organizational processes and decision-making while fostering a risk-aware culture across all levels of the organization (Standardization, 2018).

3.3.2 Application of ISO 31000 in IT Security

ISO 31000 can be applied to manage IT security risks systematically in ABC Organization. The following demonstrates its relevance:

1. Risk Identification in IT Security:

ABC should identify potential IT risks, such as unauthorized access, malware attacks, or data breaches. This step involves documenting all vulnerabilities in systems, networks, and software.

2. Risk Assessment for IT Threats:

The probability and potential impact of threats, such as firewall misconfigurations or outdated software, should be assessed. For example, an unpatched system could lead to ransomware attacks with a high financial and reputational cost.

3. Risk Treatment:

ISO 31000 suggests selecting appropriate controls for treatment.

- **Mitigation:** Implement network monitoring systems, encrypt sensitive data, and update software.
- **Avoidance:** Restrict access to sensitive systems through strong authentication.
- **Acceptance:** Document low-impact risks and monitor them continuously.

4. Integration with Existing IT Processes:

ABC can use ISO 31000 to align IT security measures with business objectives. For instance, integrating risk management into software development ensures that potential vulnerabilities are addressed during development.

5. Continuous Monitoring and Improvement:

ABC must establish regular audits to ensure the effectiveness of implemented controls. Using key performance indicators (KPIs), like incident response time or number of detected vulnerabilities, supports continuous improvement (Institute, 2021).

3.3.3 Benefits of ISO 31000 in IT Security

- **Comprehensive Approach:** Ensures all IT security risks are addressed systematically.
- **Decision Support:** Provides a framework for prioritizing and allocating resources to high-risk areas.
- **Improved Stakeholder Confidence:** Demonstrates commitment to proactive risk management, boosting trust among clients and partners.
- **Adaptability:** Applicable to evolving IT environments, including new threats like zero-day exploits or phishing campaigns (Experts, 2022).

3.4 Analysis of Possible Impacts to Security from IT Security Audit at ABC Organization

An IT security audit is a systematic evaluation of an organization's IT systems, policies, and practices to identify vulnerabilities and compliance gaps. Conducting such an audit at ABC Organization can have both **positive** and **negative** impacts on its IT security.

3.4.1 Positive Impacts

a. Identification of Vulnerabilities

The audit identifies critical security issues, such as outdated systems, weak password practices, and inadequate firewall hardening, enabling the organization to address them proactively.

- **Example:** Recognizing that employees write credentials on sticky notes allows the implementation of stricter password policies and employee training.
- **Impact:** Reduced risk of unauthorized access or data breaches.

b. Enhanced Security Measures

Recommendations from the audit (e.g., installing updated antivirus software or implementing BitLocker encryption) strengthen the organization's defense against cyber threats.

- **Impact:** Improved protection against malware, ransomware, and unauthorized data access.

c. Compliance with Regulations

The audit ensures that ABC Organization aligns with global security regulations, such as **GDPR** and **ISO 31000**, reducing the risk of legal penalties.

- **Impact:** Boosted reputation and legal compliance, ensuring trust among clients.

d. Risk Management Improvements

Audits improve risk management by categorizing threats (e.g., high, medium, or low risks) and suggesting mitigation or avoidance strategies.

- **Impact:** Prioritized resource allocation and reduced exposure to high-impact threats (Smith, 2021).

e. Employee Awareness

An audit often uncovers gaps in employee practices and includes recommendations for security training programs.

- **Impact:** Employees become more vigilant in identifying phishing attempts and maintaining good cybersecurity hygiene (Hub, 2023).

3.4.2 Potential Negative Impacts

a. Initial Costs

Addressing the findings of the audit may require significant financial investments in updated hardware, software, and additional resources.

- **Impact:** Strain on the organization's budget, especially for smaller teams.

b. Temporary Disruption

Implementing security upgrades, such as firewall configuration or software updates, may disrupt ongoing business operations.

- **Impact:** Downtime or reduced productivity during implementation phases.

c. Employee Resistance

Changes in security protocols, such as stricter password requirements or access controls, might face resistance from employees.

- **Impact:** Delayed adoption of new policies, potentially leaving vulnerabilities unaddressed.

d. Over-Confidence in Security

If the audit is not thorough, there is a risk of overlooking certain threats, leading to overconfidence in security measures.

- **Impact:** Persistent vulnerabilities may go undetected and exploited later (Team, 2022).

3.4.3 Recommendations for Mitigating Negative Impacts

1. Develop a Detailed Implementation Plan:

Schedule upgrades and configuration changes during non-peak hours to minimize disruptions.

2. Allocate Resources Wisely:

Prioritize addressing high-risk issues first (e.g., implementing BitLocker and updating operating systems).

3. Communicate with Employees:

Educate staff about the importance of new security measures and involve them in the process to reduce resistance.

4. Conduct Follow-Up Audits:

Regular audits ensure no vulnerabilities are left unaddressed and security protocols are updated as needed.

The IT security audit at ABC Organization will have a transformative impact on its IT infrastructure. By addressing vulnerabilities and improving practices, the organization will significantly enhance its overall security posture. While some short-term challenges may arise, proper planning and resource allocation can mitigate these issues, ensuring long-term benefits.

4.1 Implementation of an IT Security Policy with a Disaster Recovery Plan for ABC Organization

4.1.1 IT Security Policy for ABC Organization

What is an IT Security Policy?

An IT security policy is a comprehensive document that outlines the rules, guidelines, and practices employees and stakeholders must follow to protect an organization's data and IT infrastructure. It sets clear standards for ensuring the confidentiality, integrity, and availability of resources.

Purpose and Scope of the IT Security Policy

- **Purpose:** To safeguard ABC Organization's IT systems, reduce the risk of cyber threats, and ensure compliance with legal and industry standards (Patel, 2020).
- **Scope:** This policy applies to all employees, contractors, and stakeholders accessing the organization's IT systems, including networks, hardware, and software.

Designing Security Policies for an organization

While implementing security policies, it is important that each and one of the security policies are applied to each and one of the employees or staff in the organization. Also, the defined policies should meet the security policy principles which are the confidentiality, integrity and availability of the organization systems and data. The following policies should have in all organizations, though they can be modified, shortened, or mixed with other policies.

Policy	Focus of the Policy	Reason for the Policy
Password Creation and Management Policy	Guidelines on creating, managing, and updating passwords.	Protects systems from brute force attacks and unauthorized access by enforcing strong passwords.
Acceptable Use Policy	Rules for appropriate usage of IT resources.	Prevents misuse of systems, ensuring resources are used for business purposes only.
Data Protection Policy	Steps for safeguarding sensitive information.	Ensures compliance with GDPR, safeguarding client and employee data from breaches.
Email and Internet Usage Policy	Guidance on safe email and internet practices.	Reduces the risk of phishing attacks and malware infections through careless browsing.
Access Control Policy	Rules for granting and revoking access to IT systems.	Limits access to sensitive systems and data based on roles and responsibilities.
Incident Response Policy	Steps to handle IT security incidents.	Ensures quick response to cyber threats, minimizing damage and downtime.

Table 4: security policy for the organization ((NIST), 2020)

4.1.2 Disaster Recovery plan and its main components

4.4.2.1 What is a Disaster Recovery Plan (DRP)?

A disaster recovery plan (DRP) is a structured approach to recover critical IT systems, data, and processes following disruptions caused by natural disasters, cyberattacks, or hardware failures. It minimizes downtime and ensures business continuity (CybersecurityInsightsTeam, 2022).

4.2.2.2 Seven Components of a Disaster Recovery Plan



Figure 12: seven components of a disaster recovery plan (Kadlec, 2024)

A disaster recovery plan (DRP) is crucial for ABC Organization to address risks from hardware failures, cyberattacks, and natural disasters, ensuring minimal downtime and continuity of operations. The following seven components form the foundation of the DRP tailored for ABC Organization:

1. Risk Assessment and Business Impact Analysis (BIA)

Application:

ABC Organization must identify critical systems (e.g., customer databases, financial systems) and evaluate potential risks like ransomware attacks or server outages. The BIA assesses the impact of these risks on operations, including revenue loss and customer dissatisfaction ((NIST), 2020).

- **Action Plan:**

- ❖ Identify high-priority assets (e.g., servers, payment gateways).
- ❖ Evaluate risks like ransomware that could compromise customer data or network breaches causing service disruptions.

Example:

A ransomware attack locking the billing system could result in delayed payments and loss of client trust. Conducting a risk assessment highlights the need for encryption and multi-layered security.

2. Recovery Objectives

Application:

Define recovery metrics:

- **Recovery Time Objective (RTO):** Systems like payment processing should be restored within 4 hours to avoid financial penalties.
- **Recovery Point Objective (RPO):** Daily backups ensure no data is lost beyond the last 24 hours.

Example:

For a payment system crash, ensure backups from the previous night are used to restore data with minimal customer impact (Wallace, 2021).

3. Backup Strategies

Application:

ABC Organization should adopt the **3-2-1 backup strategy**:

- Maintain three copies of data (primary, on-site backup, off-site backup).
- Use two types of storage media (e.g., local server and cloud).
- Store one backup off-site for disaster recovery.

Example:

Daily incremental backups of customer records on cloud storage minimize recovery time in case of a server failure. Weekly full backups ensure comprehensive data protection (CybersecurityInsightsTeam, 2022).

4. Disaster Recovery Team

Application:

Create a team with defined roles and responsibilities:

- **IT Manager:** Oversees recovery operations.
- **System Administrator:** Restores data and fixes affected systems.
- **Communication Lead:** Informs stakeholders about the recovery status.

Example:

If a network breach occurs, the IT manager coordinates the technical response while the communication lead updates employees and clients (Wallace, 2021).

5. Disaster Recovery Sites

Application:

Use cloud infrastructure as a **hot site** for immediate failover, allowing ABC Organization to resume operations with minimal downtime. Alternatively, maintain a **cold site** with pre-installed hardware for cost-efficient recovery.

Example:

A critical server failure triggers a failover to a cloud-based hot site to continue business operations within minutes (Patel, 2020).

6. Communication Plan

Application:

ABC Organization must ensure clear communication during disasters:

- Establish a chain of command for reporting issues.
- Use email alerts and SMS notifications to update employees and customers.

Example:

In a data breach, the communication lead informs clients about affected services and recovery progress while adhering to GDPR guidelines for timely disclosure (CybersecurityInsightsTeam, 2022).

7. Testing and Maintenance

Application:

Regularly test the DRP through simulation drills, ensuring team members know their roles and the recovery process works effectively. Update the plan to address emerging threats and technology changes.

Example:

Simulate a ransomware attack on the billing system. Evaluate the team's response and measure the time taken to restore the system, updating the plan to fix gaps identified during testing (Wallace, 2021).

Component	Action Plan
Risk Assessment	Identify risks like ransomware, server failure, and evaluate their impact on business operations.
Recovery Metrics	Define RTO and RPO for critical systems to prioritize restoration.
Backup Strategy	Implement 3-2-1 backup to ensure redundancy and quick recovery.
Recovery Team	Assign roles to IT staff, administrators, and communication officers.
Recovery Sites	Use a hot site for immediate failover to ensure minimal disruption.
Communication	Notify stakeholders promptly during disasters, providing clear updates.
Testing	Conduct periodic simulations and refine the plan based on results.

Table 5: integrated disaster recovery plan for the organization

The above disaster recovery plan ensures ABC Organization is well-prepared to handle IT disruptions effectively. By integrating risk assessment, backup strategies, and communication protocols, the organization minimizes downtime and protects sensitive data.

4.2 Justification of the Disaster Recovery Plan for ABC Organization

The disaster recovery plan (DRP) designed for ABC Organization includes carefully selected components tailored to address its IT security challenges. Each element serves a specific purpose to mitigate risks, ensure business continuity, and protect critical data and systems. Below, the components are justified:

4.2.1 Risk Assessment and Business Impact Analysis (BIA)

Justification:

Risk assessment and BIA provide a detailed understanding of potential threats, their likelihood, and impact on organizational operations. This enables prioritization of assets and risks, such as securing customer payment systems against ransomware attacks or ensuring network uptime (Wallace, 2021).

- **Reason:** Without risk assessment, organizations may overlook critical vulnerabilities, leading to unpreparedness in crisis situations.
- **Example:** A missed assessment of outdated firewalls could allow unauthorized access during a cyberattack.

4.2.2 Recovery Objectives (RTO and RPO)

Justification:

Defining **Recovery Time Objective (RTO)** ensures essential systems are restored within a specific timeframe, minimizing downtime. **Recovery Point Objective (RPO)** ensures data backups occur frequently enough to avoid significant data loss.

- **Reason:** Clearly defined recovery objectives prevent extended outages, especially for high-priority services like customer management systems.
- **Example:** For ABC Organization, the payment system's RTO is set at 4 hours to avoid financial losses, while an RPO of 24 hours minimizes transactional data loss ((NIST), 2020).

4.2.3 Backup Strategies

Justification:

The **3-2-1 backup strategy** (three copies, two storage types, one off-site) ensures data availability even in worst-case scenarios like hardware failure or natural disasters.

- **Reason:** Without redundant backups, ABC Organization risks permanent data loss.
- **Example:** Daily incremental backups of customer data on cloud storage guarantee minimal recovery time (CybersecurityInsightsTeam, 2022).

4.2.4 Disaster Recovery Team

Justification:

A clearly defined disaster recovery team ensures swift and coordinated responses during incidents. Each team member has specific roles, from restoring systems to communicating with stakeholders.

- **Reason:** In the absence of assigned responsibilities, confusion during a disaster can delay recovery.
- **Example:** Assigning an IT Manager to oversee recovery operations ensures efficient decision-making during emergencies (Wallace, 2021).

4.2.5 Disaster Recovery Sites

Justification:

Having a **hot site** for critical operations ensures minimal downtime during emergencies. Alternatively, a **cold site** offers cost-effective recovery for less critical systems.

- **Reason:** Recovery sites provide alternative infrastructure to continue operations during disasters, avoiding complete service shutdowns.
- **Example:** ABC Organization's customer database is mirrored in a cloud-based hot site for immediate failover (Patel, 2020).

4.2.6 Communication Plan

Justification:

An effective communication plan ensures all stakeholders are informed promptly about the disaster and recovery efforts.

- **Reason:** Lack of communication can lead to panic and misinformation among employees, clients, and partners.
- **Example:** Regular updates via email and SMS keep stakeholders informed during a data breach while adhering to GDPR notification timelines (CybersecurityInsightsTeam, 2022).

4.2.7 Testing and Maintenance

Justification:

Regular testing identifies gaps in the DRP, ensuring it remains effective and up-to-date against evolving threats. Maintenance incorporates lessons from drills and updates for new technologies.

- **Reason:** A DRP that is not tested may fail during actual emergencies.
- **Example:** Simulated ransomware attacks help ABC Organization evaluate its ability to restore encrypted data promptly (Wallace, 2021).

The proposed DRP components are aligned with best practices in IT security and are tailored to ABC Organization's needs:

- **Risk assessment and BIA** enable prioritization of critical assets.
- **RTO and RPO** ensure timely recovery and minimal data loss.
- **Backup strategies** guarantee data availability.
- **Defined roles** within the disaster recovery team ensure smooth execution during crises.
- **Recovery sites** offer redundancy, enabling continued operations.
- **Clear communication protocols** prevent misinformation and maintain trust.
- **Testing and maintenance** enhance the reliability of the DRP.

By implementing this comprehensive DRP, ABC Organization mitigates risks effectively, ensuring business continuity and compliance with regulations such as GDPR.

4.3 Roles of Stakeholders in Implementing Security Audits for Organization

4.3.1 What is a Security Audit in Organizations?

A **security audit** is a comprehensive assessment of an organization's information systems to evaluate its security posture and identify vulnerabilities. The goal is to ensure that policies, procedures, and infrastructure adhere to industry standards and regulatory requirements. Security audits help mitigate risks, protect sensitive data, and build customer trust. These audits are crucial for organizations like ABC to safeguard against evolving cyber threats and comply with standards like GDPR or ISO 27001.

Two Types of Security Audits

1. **Internal Security Audits:**

Internal audits are conducted by in-house teams or departments within the organization. They focus on evaluating internal systems, processes, and controls to detect vulnerabilities and ensure compliance with internal policies. These audits are ongoing and help organizations prepare for external assessments. At ABC, an internal audit would involve checking firewall configurations and reviewing password management policies.

2. **External Security Audits:**

External audits are performed by independent third-party auditors to provide an unbiased evaluation of an organization's security framework. These audits often focus on regulatory compliance and adherence to industry standards, offering credibility and transparency. For example, an external audit for ABC would validate compliance with GDPR and ISO standards (Gillis, 2022).

4.3.2 Roles of Stakeholders in Implementing a Security Audit in the Organization

Chief Executive Officer (CEO):

The CEO plays a pivotal role by establishing security as a strategic priority and allocating necessary resources for audits. They lead efforts to foster a culture of accountability, ensuring that all departments actively engage in the audit process. Their leadership sets the tone for collaboration across the organization (Parikka, 2023).

Management Team:

Managers oversee the implementation of audit recommendations in their respective areas. They ensure employees follow security policies and that corrective actions are applied as required. Managers act as a bridge between technical teams and broader organizational operations, making audits more effective.

IT and Security Teams:

IT and security teams handle the technical aspects of audits, such as preparing logs, enabling access to auditors, and addressing vulnerabilities identified during the assessment. They ensure systems like firewalls, encryption protocols, and access controls are functioning optimally.

External Auditors:

External auditors independently assess the organization's systems and processes. Their role involves identifying vulnerabilities, evaluating compliance with regulations, and providing actionable recommendations. They offer an unbiased perspective critical for meeting regulatory and industry standards.

Legal and Compliance Team:

This team ensures the audit process aligns with legal and regulatory requirements, such as GDPR or ISO 31000. They interpret applicable laws and communicate compliance obligations to internal stakeholders, reducing legal risks for the organization (Mainse, 2023).

4.3.3 Responsibilities of Stakeholders in Implementing a Security Audit in the Organization

Chief Executive Officer (CEO):

The CEO ensures that audits align with strategic objectives and approves budgets and timelines for their execution. They are responsible for supporting compliance initiatives and reporting findings to stakeholders, including board members and investors.

Management Team:

Managers are tasked with ensuring their teams comply with security policies and follow up on implementing corrective actions. They monitor audit outcomes in their departments and collaborate with IT teams to address gaps (Sharron, 2024).

IT and Security Teams:

These teams prepare technical reports, enable necessary system access for auditors, and implement remediation plans. For ABC, this involves securing systems against threats, such as enabling BitLocker encryption or patching outdated software.

External Auditors:

Auditors evaluate risks, provide insights into best practices, and ensure compliance with global standards. They document findings and suggest actionable measures for organizations to address weaknesses.

Legal and Compliance Team:

Their responsibility lies in interpreting and enforcing applicable laws and ensuring that audit processes meet legal obligations. They guide internal teams on how to remain compliant with regulations like GDPR and address potential breaches proactively (Parikka, 2023).

Security audits are vital for organizations to identify vulnerabilities, ensure compliance with regulations, and protect critical assets. Successful implementation requires the collaboration of various stakeholders, each fulfilling their specific roles and responsibilities.

Conclusion

In conclusion, this report has outlined the critical security risks facing ABC organization and proposed a series of measures to mitigate those risks. From the analysis of security audits to the design of a disaster recovery plan, each element has been tailored to address the specific needs of the company. The importance of adhering to regulatory standards like GDPR and CCPA, as well as employing comprehensive IT security policies, cannot be overstated. By involving all relevant stakeholders in the process and fostering a culture of security awareness, ABC can enhance its overall security posture and ensure long-term protection against potential threats.

References

- (NIST), N. I. o. S. a. T., 2020. *nist.gov*. [Online]
Available at: <https://www.nist.gov/cyberframework>
[Accessed 21 11 2024].
- Anderson, R., 2016. *Security Engineering: A Guide to Building Dependable Distributed Systems*. 3 ed. Hoboken, NJ: wiley.
- Burge, S., 2023. *international security journal*. [Online]
Available at: <https://internationalsecurityjournal.com/what-is-access-control/>
[Accessed 17 10 2024].
- Chapple, M. a. S. D., 2019. *CompTIA CySA+ Study Guide*. 2 ed. Indianapolis, IN: Sybex.
- Claudia.Landivar, John.Helter, Aaron.Schifman, 2023. *cisco*. [Online]
Available at: <https://community.appdynamics.com/t5/Knowledge-Base/Proactive-monitoring-with-automated-alerts/ta-p/52441>
[Accessed 17 10 2024].
- Claudia.Landivar, 2023. *cisco*. [Online]
Available at: <https://community.appdynamics.com/t5/Knowledge-Base/Proactive-monitoring-with-automated-alerts/ta-p/52441>
[Accessed 17 10 2024].
- Commission, E., 2018. *intersoft consulting*. [Online]
Available at: <https://gdpr-info.eu/>
[Accessed 21 11 2024].
- Crockford, M., 2022. *Cybersecurity Essentials*. London, UK: Pearson.
- CybersecurityInsightsTeam, 2022. *Cybersecurity Hub*. [Online]
Available at: <https://www.cybersecurityhub.com/drp-importance>
[Accessed 25 11 2024].
- Daalen, O. v., 2023. *science direct*. [Online]
Available at: <https://www.sciencedirect.com/science/article/pii/S0267364923000146>
[Accessed 16 10 2024].
- Easttom, C., 2020. *Network Defense and Countermeasures: Principles and Practices*. 3 ed. Indianapolis, IN: Pearson IT Certification.
- Emmett Dulaney, C. E., 2021. *CompTIA Security+ Study Guide*. 8th ed. Indianapolis: Sybex.
- Experts, C., 2022. *CyberRisk Advisors*. [Online]
Available at: <https://www.cyberriskadvisors.com/iso-31000>
[Accessed 23 11 2024].
- Farrier, E., 2024. *norton*. [Online]
Available at: <https://us.norton.com/blog/how-to/the-importance-of-general-software-updates-and-patches>
[Accessed 17 10 2024].
- General, C. O. o. t. A., 2020. *oag.ca.gov*. [Online]
Available at: <https://oag.ca.gov/privacy/ccpa>
[Accessed 22 11 2024].
- Gillis, A. S., 2022. *tech target*. [Online]
Available at: <https://www.techtarget.com/searchcio/definition/security-audit#:~:text=A%20security%20audit%20is%20a,an%20established%20set%20of%20criteria.>
[Accessed 27 11 2024].
- Goel, S., 2014. *Cybersecurity: Attack and Defense Strategies*. 1 ed. Birmingham, UK: Packt Publishing.
- Gordon, D., 2021. *Network Computing*. [Online]
Available at: <https://www.networkcomputing.com/nat>
[Accessed 5 11 2024].
- Gordon, L. A., Loeb, M. P. & Lucyshyn, W., 2020. *Risk Management and Cybersecurity*. New York, NY: Springer.
- Gracy, M., 2023. *sprinto*. [Online]
Available at: <https://sprinto.com/blog/ccpa-compliance/>
[Accessed 22 11 2024].
- Gupta, R., 2018. *London*. 5th Edition ed. London: Pearson Education.
- Harshit Kumar J. Ghelani, J. K., 2023. *research gate*. [Online]
Available at:

https://www.researchgate.net/publication/372448192_Ensuring_Data_Integrity_in_Cloud_Computing_Security_Concerns_and_Countermeasures
[Accessed 17 10 2024].

Hub, C., 2023. *CyberSecurity Journal*. [Online]
Available at: <https://www.cybersecurityjournal.com/it-security-audits>
[Accessed 24 11 2024].

Institute, R. M., 2021. *RMI*. [Online]
Available at: <https://www.riskmanagementinstitute.org/iso-31000-it-security>
[Accessed 24 11 2024].

investopedia, 2024. *investopedia*. [Online]
Available at: <https://www.investopedia.com/terms/g/general-data-protection-regulation-gdpr.asp>
[Accessed 22 11 2024].

Kadlec, C., 2024. *journal of internaet banking and commerce*. [Online]
Available at: <https://www.icommercecentral.com/open-access/best-practices-in-it-disaster-recovery-planning-among-us-banks.php?aid=38334>
[Accessed 28 11 2024].

Kernitskyi, A., 2024. *obkio*. [Online]
Available at: <https://obkio.com/blog/network-visibility/>
[Accessed 17 10 2024].

Lakin, R., 2024. *iron edge*. [Online]
Available at: <https://www.ironedgegroup.com/security/its-not-too-late-for-the-windows-10-upgrade-but-you-should-act-now/>
[Accessed 4 11 2024].

Lamberti, A., 2024. *obkio*. [Online]
Available at: <https://obkio.com/blog/how-to-improve-network-performance/>
[Accessed 17 10 2024].

Liu, E., 2024. *research gate*. [Online]
Available at:
https://www.researchgate.net/publication/382029413_Early_detection_and_mitigation_of_cyber_attacks_with_machine_learning_and_artificial_intelligence
[Accessed 17 10 2024].

Liu, G., 2022. The Application of Data Encryption Technology in Computer Network Communication Security. *Hindawi*, Volume 2022, p. 10.

Mainse, N., 2023. *cybermatter*. [Online]
Available at: <https://cybermatters.info/cyber-security/security-audits/>
[Accessed 28 11 2024].

McMillan, M., 2019. The Role of Static IP Addresses in Network Management. *International Journal of Network Administration*, 45(3), p. 234-239.

Miller, E., 2022. *bitlyft*. [Online]
Available at: <https://www.bitlyft.com/resources/how-to-improve-security-with-the-nist-cybersecurity-framework>
[Accessed 23 11 2024].

Mitnick, K. a. S. W., 2011. *The Art of Deception: Controlling the Human Element of Security*. revised ed. Hoboken, NJ: wiley.

News, T. H., 2022. *The Hacker News*. [Online]
Available at: <https://thehackernews.com/2022/09/five-steps-to-mitigate-risk-of.html>
[Accessed 4 11 2024].

Osaji, F., 2020. *research gate*. [Online]
Available at: https://www.researchgate.net/publication/354294540_Hardening_the_Firewall
[Accessed 17 10 2024].

Pagnotta, S., 2024. *bit sight*. [Online]
Available at: <https://bitsight.com/blog/outdated-software-issues>
[Accessed 16 10 2024].

paloalto, 2024. *paloalto*. [Online]
Available at: <https://www.paloaltonetworks.com/cyberpedia/what-is-a-firewall>
[Accessed 5 11 2024].

Parikka, K., 2023. *falcony*. [Online]
Available at: <https://blog.falcony.io/en/the-role-of-executive-leadership-in-security-audits>
[Accessed 27 11 2024].

- Patel, M. & L. K., 2022. Firewall Hardening Techniques. *IEEE Security & Privacy*, 20(3).
- Patel, R. & S. K., 2020. Comprehensive Guide to IT Security Standards. *IT Governance Journal*.
- Romero, A., 2022. *forbs*. [Online]
Available at: <https://www.forbes.com/councils/forbestechcouncil/2022/12/01/what-to-learn-from-credential-exposures-impacting-the-worlds-top-companies/>
[Accessed 16 10 2024].
- Sharron, M., 2024. *ISMS online*. [Online]
Available at: <https://www.isms.online/iso-27001/which-stakeholders-need-to-be-involved-in-the-isms-implementation/>
[Accessed 28 11 2024].
- Smith, A. & G. T., 2021. *Cybersecurity Awareness Training*. 3rd Edition ed. New York: Wiley.
- Smith, J. & L. K., 2021. IT Governance and Risk. *IT Governance and Risk*.
- Standardization, I. O. f., 2018. *ISO.org*. [Online]
Available at: <https://www.iso.org/standard/65694.html>
[Accessed 20 11 2024].
- Stoneburner, G., Goguen, A. & Feringa, A., 2012. *NIST*. [Online]
Available at: <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>
[Accessed 25 10 2024].
- Tance Suleski, M. A. E. W., 2023. *sage journals*. [Online]
Available at: <https://journals.sagepub.com/doi/10.1177/20552076231177144>
[Accessed 17 10 2024].
- Tariq, R. a. B. A., 2018. *Information Security Risk Management for ISO27001/ISO27002*. 2 ed. Cambridgeshire, UK: IT Governance Publishing.
- Taylor, R., 2020. *Vulnerability Management in Modern IT*. 1st Edition ed. Berlin: Springer.
- Team, T. E., 2022. *TechInsight*. [Online]
Available at: <https://www.techinsight.com/security-audit>
[Accessed 24 11 2024].
- Terra, J., 2024. *simpli learn*. [Online]
Available at: <https://www.simplilearn.com/importance-of-security-awareness-training-article>
[Accessed 17 10 2024].
- Tittel, E., 2020. *computer networking*. [Online]
Available at: <https://www.computernetworking.com/what-is-dmz>
[Accessed 5 11 2024].
- T, N., 2022. *ISO docs*. [Online]
Available at: <https://iso-docs.com/blogs/iso-concepts/iso-31000-risk-management>
[Accessed 23 11 2024].
- Tunggal, A. T., 2024. *upgurad*. [Online]
Available at: <https://upguard.com/blog/compliance-monitoring>
[Accessed 17 10 2024].
- Union, E., 2016. *General Data Protection Regulation (GDPR)*. [Online]
Available at: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679>
[Accessed 24 10 2024].
- V.B. Godagama, H. P. A. B. M. H. P., 2023. *research gate*. [Online]
Available at: https://www.researchgate.net/publication/372741546_Cost-Effective_Investment_to_Monitor_the_Network_Infrastructure_of_Small_and_Medium-Scale_Enterprises
[Accessed 17 10 2024].
- Wallace, M. & W. L., 2021. *Disaster Recovery Planning: A Guide for IT Professionals*. 3rd ed. London: Elsevier.
- WIKIPEDIA, 2024. *wikipedia*. [Online]
Available at: https://en.wikipedia.org/wiki/Symmetric-key_algorithm
[Accessed 4 11 2024].
- Williams, J., 2019. *Data Security Best Practices*. 2nd Edition ed. Boston: O'Reilly Media.
- Wilson, L., 2021. Multi-Factor Authentication in Organizations. *Journal of Information Security*, 35(4).
- yasar, k., 2022. *tech target*. [Online]
Available at: <https://www.techtarget.com/whatis/definition/information-security-management-system-ISMS>
[Accessed 22 11 2024].